

NARRATIVA EXPLICATIVA: EL ARTE LITERARIO E IRÓNICO DE LA ENCUESTA DE CIBERSEGURIDAD

Reflexión Propositiva sobre la Evaluación de Seguridad Organizacional

Versión: 1.0 | **Fecha:** Enero 2026

Autor: Consorcio de Estrategias Ciberseguridad

Tono: Irónico, constructivo, propositivo | **Estilo:** Literario con rigor técnico

INTRODUCCIÓN: LA IRONÍA COMO HERRAMIENTA DE TRANSFORMACIÓN

La ciberseguridad organizacional es un juego extraño donde todos sabemos que el castillo está en llamas, pero cada uno mira hacia un lado diferente. El CISO ve las murallas que necesitan reforzarse. El CFO ve presupuestos que no se justifican. El CTO ve tecnología que no está integrada. El empleado ve una contraseña más que memorizar.

Esta encuesta no propone ser un tribunal donde se sentencian culpables de negligencia. Tampoco es un test de aprobado/suspense donde marcamos casillas y proclamamos victoria. Es, más bien, un espejo estratégico—a veces incómodo, frecuentemente revelador, siempre propositivo.

La ironía es nuestra herramienta predilecta porque la realidad de la ciberseguridad contemporánea *merecería* la ironía de Cervantes. Hablamos de "madurez de ciberseguridad" en organizaciones donde las contraseñas siguen siendo "123456". Nos jactamos de "gobernanza integrada" mientras el CISO reporta al responsable de impresoras. Predicamos "conciencia continua" mientras el 87% de empleados todavía clica phishing obviamente falso.

Pero aquí está lo importante: la ironía no es desprecio. La ironía es reconocimiento de brecha entre aspiración y realidad—y brecha es oportunidad.

PARTE I: LA FILOSOFÍA DE LA ENCUESTA

El Problema de Medir lo Inmensurable (y por qué lo hacemos de todas formas)

La ciberseguridad es un dominio donde la perfección es imposible pero el progreso es medible.

Un sistema completamente seguro sería un sistema completamente inutilizable. Una organización con "riesgo cero" sería una organización que no hace negocio. Por lo tanto, la pregunta real que nos hacemos nunca es "¿Estamos seguros?" sino "¿Estamos seguros *suficientemente*?" y "¿Nos estamos moviendo en la dirección correcta?"

La encuesta que propone este documento reconoce una verdad incómoda: **el 95% de la madurez ciberseguridad**

no es sobre tecnología. Es sobre gobernanza, decisiones humanas, alineación estratégica y, fundamentalmente, sobre si la organización quiere ser segura o si simplemente quiere parecer segura.

Una organización puede invertir millones en SIEM, Endpoint Detection & Response, Artificial Intelligence para detección de amenazas. Pero si el CISO reporta al VP de Infraestructura y no al CEO, si el presupuesto se determina anualmente al margen de risk appetite, si los empleados reciben entrenamiento de seguridad una vez al año mientras reciben actualizaciones de phishing diariamente—entonces toda esa inversión es una estatua de bronce en un museo lleno de humo.

La encuesta mide esto. No porque podamos cuantificar gobernanza (imposible). Sino porque podemos ver sus síntomas: ¿Reporta el CISO al CEO? ¿Se revisa estrategia ciberseguridad trimestralmente? ¿Existe presupuesto multianual? Estos indicadores son proxies imperfectos pero útiles de gobernanza real.

La Escala de Madurez: Del Caos Adorable al Orden Vigilante

La escala de 0-5 (Inexistente → Optimizado) que estructura esta encuesta no es capricho. Deriva de frameworks reconocidos mundialmente: NIST Cybersecurity Framework, ISO 27001, SANS C2M2, CMM (Capability Maturity Model). Pero aquí está el secreto: ninguno de estos frameworks es "correcto" en sentido absoluto. Cada uno es una lente diferente sobre la misma realidad.

Nos tomamos la libertad de integrar todos ellos porque creemos que la verdad está en la intersección, no en el dogma.

Nivel 0 - Inexistente: Se traduce en "hemos escuchado que ciberseguridad es importante." La organización opera bajo el principio de la Esperanza—una estrategia sorprendentemente popular que funciona hasta que no.

Nivel 1 - Inicial: Se traduce en "tenemos alguien encargado." Que sea el junior de IT que heredó "seguridad" como tarea entre cambios de contraseña es detalle administrativo menor. Aquí existe cierta fricción con la realidad.

Nivel 2 - Repetible: Se traduce en "hemos documentado qué hacer." Las cosas suceden más o menos consistentemente. Hay un plan. El plan a veces se sigue. Es como tener una dieta—existe; si realmente se sigue es asunto separado.

Nivel 3 - Definido: Se traduce en "sabemos qué hacer, por qué lo hacemos, y lo hacemos". Hay métricas. Hay responsabilidades. Hay integración. Es, francamente, sorprendente cuántas organizaciones nunca alcanzan este nivel.

Nivel 4 - Cuantitativamente Gestionado: Se traduce en "medimos cada metro del camino." Automatización empieza a hacerse cargo del trabajo tedioso. Los humanos se enfrentan a excepciones, no a tareas. Es soñador pero posible.

Nivel 5 - Optimizado: Se traduce en "la ciberseguridad es casi invisible porque funciona tan bien." Aquí habitan tres organizaciones en el mundo. Probablemente ellas también están mencionando mientras leen esto, "bueno, más o menos optimizado."

La Ironía de "Madurez"

Llamamos "madurez" a esto, pero es irónico. La palabra sugiere calma, solidez, un cierto reposo después de crecimiento. La realidad es lo opuesto. Madurez en ciberseguridad es vigilancia eterna. Es inquietud productiva. Es la aceptación de que el trabajo nunca termina.

El malware de hoy queda obsoleto mañana cuando un investigador de seguridad en una universidad rusa descubre una nueva primitiva de ataque. El framework que defendía perfectamente el año pasado ahora tiene una vulnerabilidad publicada. El empleado que estaba perfectamente entrenado en phishing ahora enfrenta deepfake de CEO que imita voces.

"Madurez" no significa "hemos ganado." Significa "hemos construido un sistema que nos permite cambiar continuamente." Es Sísifo con mejor infraestructura de TI.

PARTE II: LOS SIETE MÓDULOS—EL VIAJE DESDE LA ANARQUÍA AL ORDEN

Módulo 1: Gobernanza—Donde Todo Comienza (o No)

La Pregunta Fundamental: ¿Alguien está realmente a cargo de ciberseguridad, o es una tarea colectiva que todos evitan?

Gobernanza es donde 80% de los problemas nacen. No porque TI sea incompetente (rara vez lo es), sino porque ciberseguridad requiere **autoridad transversal**. Afecta todas las áreas: finanzas (fraude, ransomware), recursos humanos (social engineering), legal (compliance, liability), operaciones (availability).

Cuando el CISO reporta al VP de Infraestructura—que naturalmente quiere maximizar disponibilidad y minimizar fricción—la seguridad se convierte en "la cosa que ralentiza nuestros cambios". Cuando

reporta
al CEO, se convierte en "el factor que protege nuestro negocio."

Esta no es una diferencia semántica. Es la diferencia entre una función que actúa como guardarrail y una
que actúa como remolque de baja velocidad.

Ironía Local: Escuchamos constantemente "la seguridad es responsabilidad de todos." Exacto. Y cuando responsabilidad es de todos, típicamente es de nadie. Es el equivalente organizacional de "alguien debería hacer algo."

La Pregunta que Articula Madurez: ¿Con qué frecuencia se revisa ciberseguridad con liderazgo ejecutivo?

Si la respuesta es "nunca" o "cuando hay incidente", entonces ciberseguridad está en el asiento de atrás del coche de la estrategia corporativa. Si es "trimestralmente", está en el tablero. Si es "mensualmente", está en la mesa ejecutiva donde realmente viven las decisiones.

Módulo 2: Vulnerabilidades—El Juego de Whack-a-Mole Digitalizado

La Pregunta Fundamental: ¿Qué tan rápido encontramos vulnerabilidades y qué tan rápido las solucionamos?

Este módulo captura la realidad táctica de seguridad: hay agujeros. Siempre los hay. La pregunta es si los dejamos abiertos el tiempo suficiente para que alguien más los encuentre.

Ironía Local Número 1: Vulnerabilities son como plagas de jardín. Pueden ignorarse temporalmente porque se ven menores. Luego aparecen en cantidad tales que han comido toda la cosecha. Las organizaciones que hacen scanning cada trimestre inevitablemente descubren que el bug que encontraron esta semana probablemente llevaba tres meses exponiendo datos.

Ironía Local Número 2: Las organizaciones malas ignoran vulnerabilidades. Las organizaciones mediocres las scanean una vez al año y generan un informe masivo de 2,000 items que luego es demasiado de procesar. Las organizaciones buenas escanean continuamente, priorizan por riesgo real (no solo CVSS score), y remedian sistemáticamente. El volumen *es menor* porque manejan la salida en tiempo real.

Penetración Testing: Aquí es donde la realidad duele más. Un test de penetración profesional es cuando decidimos contratar a alguien para atacar nuestro sistema *con permiso*. Y la verdad desconcertante es que si tienes que *contratar a alguien* para encontrar cómo atacarte, probablemente has tenido suerte anormalmente larga.

Los mejores equipos de seguridad hacen esto internamente (red teaming) continuamente. Simulan ataques reales, documentan qué funcionaría, y luego de los dejan ganar ocasionalmente para que vean en acción cómo sus defensas se desmoronan, para que la lección sea visceral y memorable.

Módulo 3: SIEM—El Diario de la Inseguridad

La Pregunta Fundamental: ¿Estamos viendo lo que sucede en nuestros sistemas?

Un SIEM (Security Information and Event Management) es fundamentalmente un diario de todo lo que sucede en tu infraestructura. Con 10 millones de eventos por día, si no tienes buena indexación, análisis y filtrado, tu diario es ruido blanco digital.

Ironía Central: La mayoría de organizaciones que despliega SIEM genera tan tantas alertas falsas que el equipo de seguridad desarrolla lo que se llama "fatiga de alertas." Ignoran más del 95% de alertas porque el 95% son falsos positivos. Es como vivir en una casa donde la alarma suena constantemente por viento—eventualmente dejas de escucharla.

La Verdad Incómoda: Un SIEM mal configurado es *peor* que no tener SIEM. Te da la ilusión de visibilidad mientras en realidad estás ciega. Es Platón's cave con subprocesos.

Las organizaciones maduras invierten en *tuning* de SIEM. Lo cual significa: alguien dedica 20% de su tiempo a reducir ruido. Lo cual significa: presupuesto. Lo cual significa: priorización ejecutiva. Volvemos a gobernanza.

Módulo 4: Acceso e Identidad—La Puerta Principal

La Pregunta Fundamental: ¿Quién tiene acceso a qué, y estamos seguros?

Identidad es donde comienzan 60% de los ataques modernos. No porque sea fácil hackear sistemas—es difícil.

Sino porque es *trivial* hackear usuarios. Phishing. Ingeniería social. Un atacante no quiere vencer tu firewall. Quiere tu contraseña de empleado para estar *dentro* del firewall.

Ironía Central: Enseñamos a la gente a usar contraseñas complejas. Luego descubrimos que escriben "P@ssw0rd123!" en el post-it pegado al monitor porque es "compleja" pero *memorable*. Enseñamos sobre MFA. Luego descubrimos que muchos evitan activarlo porque "ralentiza acceso."

La verdad: seguridad es fricción. La pregunta es si es fricción *necesaria* o *diseño pobre*. Una organización madura usa friction smartly: MFA para lo crítico, verificación conductual para lo riesgoso, pero flujo sin fricción para lo cotidiano.

Módulo 5: Capacitación—La Batalla por las Mentes

La Pregunta Fundamental: ¿Realmente los empleados entienden ciberseguridad o solo simulan?

Aquí está donde la realidad es más cruda. Estudio de UCSD 2025: 19,500 empleados, 8 meses, phishing simulado. Resultado: No hay correlación entre haber completado "capacitación anual" y no caer en phishing.

Peor: *más empleados cayeron conforme avanzaba el tiempo*. El mes uno: 10%. Mes ocho: 50%.

Ironía Central: La capacitación de conciencia típica funciona así: La organización compra un LMS (Learning Management System), carga un video de 30 minutos sobre "phishing 101", obliga a todos a completarlo, genera reporte que dice "100% compliance," y declara victoria.

Lo que no mide es: ¿Qué recordaron? ¿Cambió comportamiento? ¿Reportan ahora phishing más rápido?

Las organizaciones maduras hacen esto diferentemente: entrenamiento continuo pequeño, relevante, justo a tiempo. Simulación de phishing, pero con *feedback inmediato* (no castigo). Gamification que celebra reportar amenazas. Historias que resuenan (no diapositivas genéricas).

Métrica que Importa: No es "% completó entrenamiento." Es "% de phishing simulado que fue reportado rápidamente." Eso es comportamiento. Eso es resultado.

Módulo 6: Respuesta a Incidentes—Cuando Todo Falla

La Pregunta Fundamental: ¿Qué hacemos cuando sucede lo inevitable?

Todo incidente responde a esta secuencia:

1. **Detección:** ¿Nos damos cuenta que algo está mal?
2. **Investigación:** ¿Qué pasó exactamente?
3. **Contención:** ¿Cómo lo pausamos ahora?
4. **Erradicación:** ¿Cómo eliminamos la causa?
5. **Recuperación:** ¿Cómo volvemos a funcionar?
6. **Lecciones Aprendidas:** ¿Por qué sucedió y cómo prevenimos que vuelva?

Las organizaciones inmaduras omiten los pasos 4, 5 y 6. O los hacen pero no documentan. O documentan pero no integran feedback a defensas.

Ironía Central: Observamos constantemente: después de un incidente mayor, la organización compra herramienta cara de seguridad que teóricamente hubiera prevenido el problema. Nunca pregunta: "¿Por qué no detectamos esto? ¿Por qué tardamos 6 meses en darnos cuenta?" Salta directamente a "compramos solución" cuando la solución real es proceso.

El MTTR (Mean Time to Respond) es métrica clave. Si promedio es "3 semanas," significa que incidente típicamente está causando daño 3 semanas antes de actuar. Si es "<2 horas," significa que los defenses funcionan dinámicamente.

Módulo 7: Integración Estratégica—La Sinfonía, No Solos

La Pregunta Fundamental: ¿Es ciberseguridad parte de cómo hacemos negocio, o es un departamento que se interpone?

Organizaciones inmaduras piensan en ciberseguridad como "fondo"—algo que existe para cumplir requisitos (compliance), no para crear valor. Organizaciones maduras la piensan como "infraestructura": parte de cómo deciden tecnología, partners, diseño producto.

Ejemplo Concreto: Una organización inmadura compra software SaaS, pregunta "¿Es seguro?", recibe "sí," lo despliega. Una organización madura hace security assessment: ¿Cómo manejan datos? ¿Criptografía en tránsito? ¿Segregación tenant? ¿Qué pasa si son hackeados? ¿Cuál es plan de salida si terminamos contrato?

PARTE III: LA IRONÍA COMO MOTOR DE TRANSFORMACIÓN

"Somos Nivel 2. ¿Es Esto Malo?"

No. Nivel 2 (Repetible) es donde comienza la verdadera seguridad. Nivel 0 es no-existencia. Nivel 1 es esperanza. Nivel 2 es cuando dicen "tenemos proceso documentado y se repite con consistencia."

Problema: muy pocas organizaciones aceptan estar en Nivel 2. Escuchan "Nivel 2" y oyen "F grade." Entonces simulan estar en Nivel 3 o 4. Cuelgan certificaciones en paredes. Publican decalogs que dicen "SOC 24/7 operational excellence." Generan reportes que muestran métricas.

Pero aquí está la verdad: es mejor estar honestamente en Nivel 2 y moviéndose a Nivel 3 que *fingir* estar en Nivel 4. El primero es realista y sostenible. El segundo es castillo de naipes que colapsa en el primer incidente real.

Proposición Central: La encuesta premisa es que **honestidad es prerequisite de mejora**. No porque honestidad sea moralmente superior, sino porque es estratégicamente superior. Si sabes dónde estás realmente, puedes trazar camino realista hacia dónde quieres estar. Si nadas en ilusión, el camino es espejismo.

Las Tres Trampas de Autoevaluación

Trampa 1: Aspiracional vs Real

Pregunta CISO: "¿Cada cuánto haces phishing simulation?"

CISO: "Mensualmente."

Investigación adicional: "¿De verdad cada mes?"

CISO: "Bueno, nuestro plan es mensual. En realidad ejecutamos el último hace cuatro meses."

Esto es aspiracional vs real. El plan es excelente. La realidad... menos.

La Encuesta Lo Captura: La encuesta incluye preguntas de validación cruzada. Si dices "MFA universal"

pero "presupuesto <3% IT," hay conflicto. No significa que mientes, pero significa que hay o
acompromiso

no-declarado o algo falta de contexto. Un buen facilitador lo tira.

Trampa 2: Confundir Herramientas con Capabilidad

"¿Tenemos SIEM?"

"Sí, Splunk."

Lo cual es respuesta a "¿tenemos herramienta?" no a "¿podemos detectar amenazas?" Son diferentes preguntas.

Hemos visto organizaciones con Splunk costosísimo que genera 50,000 alertas/día y el equipo responde manualmente a menos de 1%. Es herramienta cara. Capacidad = cero.

La Encuesta Lo Captura: Preguntas sobre integración, tuning, false positive rate, threat hunting.

No preguntas sobre "¿qué software tienes?" sino "¿qué *haces* con software?"

Trampa 3: Confundir Compliance con Seguridad

Las organizaciones más compliance-focused ("cumplimos GDPR", "pasamos auditoría ISO 27001") no son necesariamente las más seguras.

Es porque compliance es checklist. Seguridad es proceso continuo. Alguien puede "cumplir GDPR" en escritura (tenemos política, tenemos DAP, tenemos encryption) pero no en espíritu (datos realmente seguro, vendor realmente veted, incidente realmente investigado).

La Encuesta Lo Captura: Distingue entre "existe política" vs "se ejecuta" vs "se mide" vs "se optimiza continuamente."

PARTE IV: LA PROPUESTA—¿QUÉ HACER CON ESTA ENCUESTA?

Cambio de Mentalidad Necesario

Esta encuesta es herramienta de transformación, no auditoría punitiva.

Si eres CISO presentando esto a junta: *no* presentes como "miren dónde estamos fallando." Presenta como "aquí está brújula. Aquí están waypoints realistas. Aquí es donde logramos ventaja competitiva."

Si eres responsable de implementar: no pierdas tiempo justificando por qué estás en Nivel 2. Usa momentum para alcanzar Nivel 3. La trayectoria importa más que posición absoluta.

Los Tres Pasos de Transformación

Paso 1: Aceptación Honesta

Acepta dónde realmente estás. Sin bravuconería. Sin minimización. Los datos son lo que son.

Si SIEM está generando 40% false positives, esa es realidad. Tuning es trabajo. Presupuesto se requiere. Tiempo se necesita. Pero es realista.

Paso 2: Priorización Estratégica

De los siete módulos, ¿cuáles tres importan más para *tu* organización?

Una organización financiera: Gobernanza, Acceso, Respuesta a Incidentes (compliance + fraude).

Una startup tech: Gobernanza, Vulnerabilidades, Capacitación (velocidad + cultura).

Una utility crítica: Vulnerabilidades, SIEM, Respuesta a Incidentes (availability + resilience).

No intentes arreglar todo simultáneamente. Imposible. Arregla lo que importa. Luego construye desde ahí.

Paso 3: Medición Continua

Repite encuesta cada 12 meses. No porque te dé score final, sino porque te muestra *velocidad* de cambio.

Pasar de Nivel 2 a Nivel 3 en un módulo en 12 meses es excelente progreso. Permanecer en Nivel 2 mientras mundo está en Nivel 4 es riesgo creciente.

CONCLUSIÓN: LA IRONÍA COMO ESPERANZA

Hemos escrito esta narrativa en tono irónico porque la ironía es forma de humor que reconoce realidad incómoda y *simultáneamente* propone que es solucionable.

Es fácil escribir sobre ciberseguridad en tono desesperado: "Amenazas aumentan exponencialmente, nada es seguro, todos están comprometidos." Eso es probablemente verdad.

Es fácil escribir en tono utópico: "Con framework correcto, herramientas correctas, y commitment ejecutivo, seremos seguros." Eso también es probablemente verdad, pero requiere fe.

La ironía es el camino del medio. Dice: "Sí, estamos en situación imperfecta. Sí, los atacantes son realmente buenos. Sí, recursos siempre son insuficientes. Y *simultáneamente*, si entendemos donde estamos, elegimos batallas inteligentemente, y ejecutamos consistentemente, podemos reducir riesgo materialmente."

Eso no es nirvana. Pero tampoco es desesperación.

Es simplemente... posible. Y eso, en ciberseguridad, es todo lo que tenemos.

"No conozco el secreto del éxito, pero el secreto del fracaso es tratar de complacer a todos.

—Bill Cosby (y también: ciberseguridad)"

Cuando está encuesta te muestre que estás en Nivel 2, recuerda: es nivel donde empieza el verdadero trabajo. Es donde dejas de esperar que alguien más arregle las cosas y comienzas a arreglarlas tú.

Es incómodo. Es difícil. Es también revolucionario.

Bienvenido al viaje.